ADscan

AD CONTROL COVERAGE REPORT

What we *tested*, and *how*.

Absence of a finding is only assurance if the control was actually checked. This report lists the 22 controls exercised against essos.local, states the specific check run against each, and marks which came back clear.

CONTROLS TESTED	VERIFIED CLEAR	NEEDS ATTENTION
22	0	22

Generated October 09, 2026
Scope essos.local

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

COVERAGE SUMMARY TESTED IN THIS ENGAGEMENT

Every control here was *actively checked*.

Every control below was actively exercised during this assessment, and each entry states the check that was run: the attribute read, the protocol negotiated, the call issued. A control marked **verified clear** means that check was run and the weakness was not there, which is assurance you can put in front of a board or an auditor.

> None of the controls tested came back clear. That is a finding about the directory, not a limit on the depth of the assessment: each of the 22 entries below was actively exercised, and each one held a weakness. The severities and the remediation sequence are in your Security Assessment Report.

CONTROLS TESTED	VERIFIED CLEAR	NEEDS ATTENTION
22	**0**	**22**
distinct control areas exercised across scope.	checked this engagement; no weakness present.	tested and present: tracked in the Security Assessment Report.

> A control is marked verified clear only when ADscan positively observed it holding, never inferred from the absence of a finding. This run produced no such observed-good reading for any mapped control, so none is marked clear above.

TESTED & PRESENT 22 CONTROLS

Tested, and *found* something.

These control areas were checked and a weakness was present. The full finding, severity, and step-by-step remediation live in your Security Assessment Report and AD Hardening Playbook.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Accounts with Non-Expiring Passwords

NEEDS ATTENTION

2026-08-02

Checked: Read the userAccountControl flags of every enabled account for the bit that exempts it from password expiry, and separated the administrative accounts from the rest so the exposure is weighed by what each account can reach.

PRESENT · Enabled accounts are exempt from password expiry, so their credentials stay valid indefinitely, including any copy taken during an incident nobody detected.

SECURITY ASSESSMENT REPORT → Accounts with Non-Expiring Passwords

DORA Art. 5, Art. 6, Art. 9.4 **NIS2** 21.2.j, 21.2.i

A certificate template lets an ordinary user request a certificate in another account's name

NEEDS ATTENTION

2026-08-03

ADCS ESC1 - Misconfigured Certificate Template

Checked: Read every published certificate template and looked for the combination that lets a requester name someone else: the enrollee-supplies-subject flag set in msPKI-Certificate-Name-Flag, an Extended Key Usage that permits client authentication, no manager approval, no enrollment-agent countersignature, and at least one non-administrative principal holding Enroll rights.

PRESENT · A template lets an ordinary requester name the account the certificate speaks for, and the domain accepts that name when the certificate is later used to log on. The affected template and the principals holding Enroll rights on it are named in your Security Assessment Report.

SECURITY ASSESSMENT REPORT → ADCS ESC1 - Misconfigured Certificate Template

DORA Art. 9.4, Art. 17, Art. 19 **NIS2** 21.2.h, 21.2.i

Authentication certificates are matched to accounts by name, not a strong identifier

NEEDS ATTENTION

2026-08-03

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

Checked: Identified authentication templates whose subject is built from the requester's user principal name or e-mail address rather than from a strong identifier, and confirmed whether they enroll without approval to principals outside the administrative tier: the template-side precondition for abusing a weak explicit certificate mapping.

PRESENT · Authentication certificates are issued on a name-based subject. Where an account is mapped to a certificate by that name rather than by a strong identifier, a certificate can be made to fit the mapping.

SECURITY ASSESSMENT REPORT → ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

DORA Art. 9.4 **NIS2** 21.2.h

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

A certificate template issues certificates usable for any purpose, including logon

NEEDS ATTENTION

2026-08-03

ADCS ESC2 - Any Purpose Certificate Template

Checked: Compared each template's Extended Key Usage list against the Any Purpose OID (2.5.29.37.0) and against the empty case, then confirmed whether such a template issues without approval or a countersignature to a principal outside the administrative tier.

PRESENT · A template issues certificates with no usage restriction, so a certificate obtained for one stated purpose is equally valid for logging on as the account that requested it.

SECURITY ASSESSMENT REPORT → **ADCS ESC2 - Any Purpose Certificate Template**

DORA Art. 9.4 **NIS2** 21.2.h, 21.2.i

Ordinary users can obtain enrollment-agent certificates that request in other names

NEEDS ATTENTION

2026-08-03

ADCS ESC3 - Enrollment Agent Template Abuse

Checked: Looked for the Certificate Request Agent usage on any template a non-administrative principal may enroll in, since that usage lets the holder request certificates in another person's name, and checked whether the enrollment would be held for manager approval.

PRESENT · An enrollment-agent certificate is obtainable from below the administrative tier. Whoever holds one can ask the authority for certificates in other people's names, and the authority will issue them.

SECURITY ASSESSMENT REPORT → **ADCS ESC3 - Enrollment Agent Template Abuse**

DORA Art. 9.4 **NIS2** 21.2.h, 21.2.i

Non-administrators can rewrite the configuration of a certificate template

NEEDS ATTENTION

2026-08-03

ADCS ESC4 - Vulnerable Certificate Template ACL

Checked: Read the security descriptor of every certificate template object and resolved which principals hold write-equivalent rights over it (GenericAll, GenericWrite, WriteDacl, WriteOwner, or ownership), because a template's configuration is only as trustworthy as the set of people who can rewrite it.

PRESENT · Principals outside the administrative tier can rewrite a certificate template. Whatever that template's settings are today, they are only as strong as the discretion of everyone on that access list.

SECURITY ASSESSMENT REPORT → **ADCS ESC4 - Vulnerable Certificate Template ACL**

DORA Art. 9.4 **NIS2** 21.2.h, 21.2.i

Non-administrators can rewrite the certificate-authority objects the domain trusts

NEEDS ATTENTION

2026-08-03

ADCS ESC5 - Vulnerable CA Object ACL

Checked: Extended the same access-control review to the PKI objects above the templates (the enterprise CA object, the root CA and intermediate CA entries, and the NTAuth certificate store), and listed any principal outside the administrative tier holding write access to them.

PRESENT · Write access to the PKI objects themselves reaches below the administrative tier. That is control over what the domain trusts, which sits above any individual template setting.

SECURITY ASSESSMENT REPORT → **ADCS ESC5 - Vulnerable CA Object ACL**

DORA Art. 9.4 **NIS2** 21.2.h, 21.2.i

Non-administrators hold certificate-authority management rights

NEEDS ATTENTION

2026-08-03

ADCS ESC7 - Certificate Authority Privilege Abuse

Checked: Read the certification authority's own security descriptor from the CA host and resolved who holds the Manage CA and Manage Certificates rights, which between them allow the CA's policy to be changed and pending requests to be approved.

PRESENT · CA management rights extend to principals outside the administrative tier. Manager approval is the safeguard several template settings fall back on, and whoever holds these rights is the person granting it.

SECURITY ASSESSMENT REPORT → **ADCS ESC7 - Certificate Authority Privilege Abuse**

DORA Art. 9.4 **NIS2** 21.2.h, 21.2.i

The certificate web-enrollment page accepts a relayed Windows logon

NEEDS ATTENTION

2026-08-03

ADCS ESC8 - NTLM Relay to Web Enrollment

Checked: Requested the CA's web enrollment page over HTTP and HTTPS and read the authentication challenge it returned, to establish whether the endpoint accepts a Windows authentication that was captured elsewhere, and, on the HTTPS endpoint, whether channel binding is enforced, which defeats that reuse.

PRESENT · The web enrollment endpoint accepts a Windows authentication without binding it to the connection it arrived on, so a logon prompted out of a privileged machine can be spent here for a certificate in that machine's name.

SECURITY ASSESSMENT REPORT → **ADCS ESC8 - NTLM Relay to Web Enrollment**

DORA Art. 9.4, Art. 9.3 **NIS2** 21.2.h, 21.2.e

Authentication certificates are issued without the requester's account identifier

NEEDS ATTENTION

2026-08-03

ADCS ESC9 - No Security Extension on Certificate Template

Checked: Inspected each template's msPKI-Enrollment-Flag for the bit that omits the security extension binding the requester's account SID into the issued certificate. Without that binding, the certificate is matched to an account by name rather than by identifier.

PRESENT · A template issues authentication certificates without the account identifier inside them. The certificate is then matched to whoever currently holds the name it carries, and names in a directory can be changed.

SECURITY ASSESSMENT REPORT → **ADCS ESC9 - No Security Extension on Certificate Template**

DORA Art. 9.4 **NIS2** 21.2.h

Some accounts let the domain hand out password material with no login

NEEDS ATTENTION

2026-08-03

AS-REP Roasting

Checked: Read the userAccountControl flags of every enabled account for the one that waives Kerberos pre-authentication, then asked the domain controller for each such account's initial ticket without presenting any credential, to confirm the reply really is issued and really is encrypted with that account's password key.

PRESENT · The domain controller issued pre-authentication-free replies containing password-derived material, which anyone able to reach the domain controller can collect without holding an account.

SECURITY ASSESSMENT REPORT → AS-REP Roasting

DORA Art. 6, Art. 9.4 **NIS2** 21.2.h, 21.2.j

The domain controller still accepts the reversible NTLMv1 logon protocol

NEEDS ATTENTION

2026-08-03

Domain Controller Accepts NTLMv1 Authentication

Checked: Prompted the domain controller to authenticate back to a listener under this assessment's control and recorded the protocol version it actually negotiated on the wire, rather than inferring it from policy settings.

PRESENT · The domain controller completed the exchange using the legacy protocol version, whose response can be reversed to the machine account's password key with commodity computing.

SECURITY ASSESSMENT REPORT → Domain Controller Accepts NTLMv1 Authentication

DORA Art. 6, Art. 9.3, Art. 9.4 **NIS2** 21.2.e, 21.2.h

Managed service-account passwords can be read by non-administrators

NEEDS ATTENTION

2026-08-03

gMSA Password Readable by Non-Admins

Checked: Parsed the msDS-GroupMSAMembership security descriptor on each group managed service account and resolved, through nested group membership, exactly which principals are entitled to retrieve the account's managed password.

PRESENT · Managed service account passwords are retrievable by principals outside the administrative tier, so the rotation those accounts rely on buys nothing against anyone already on that list.

SECURITY ASSESSMENT REPORT → gMSA Password Readable by Non-Admins

DORA Art. 9.2 **NIS2** 21.2.i

Service-account passwords can be pulled from the domain and cracked offline

NEEDS ATTENTION

2026-08-03

Kerberoasting

Checked: Enumerated every account carrying a servicePrincipalName and requested a service ticket for it, then examined the encryption type the domain controller issued: a ticket encrypted with the account's own password key is material any authenticated user can take away and attack offline.

PRESENT · Service tickets were obtainable for accounts whose password key encrypts them, giving any authenticated user material to attack offline at their own pace and without further contact with the domain.

SECURITY ASSESSMENT REPORT → Kerberoasting

DORA Art. 6, Art. 9.4 **NIS2** 21.2.h, 21.2.j

Legacy SMBv1 protocol

NEEDS ATTENTION

2026-08-02

Checked: Negotiated with the SMB service on each reachable host to see whether the deprecated SMBv1 dialect is still accepted.

PRESENT · One or more hosts still accept SMBv1, keeping a deprecated dialect with no message signing and a known wormable exploit class reachable on the network.

SECURITY ASSESSMENT REPORT → SMBv1 Protocol Enabled

DORA Art. 6, Art. 9.3 **NIS2** 21.2.e, 21.2.a

Local administrator password management (LAPS)

NEEDS ATTENTION

2026-08-03

Checked: Queried the directory for the LAPS password attributes on domain computer objects to establish whether local administrator passwords are centrally managed and rotated.

PRESENT · Local administrator passwords are centrally managed, but the attribute holding them is readable by principals outside the administrative tier: the managed password can be retrieved from the directory by an account that should never see it, and the rotation buys nothing against that account.

SECURITY ASSESSMENT REPORT → LAPS Password Readable by Non-Admins

DORA Art. 9.4 **NIS2** 21.2.i

Ordinary users can create their own computer accounts

Machine Account Quota Allows Domain Join

NEEDS ATTENTION

2026-08-02

Checked: Read ms-DS-MachineAccountQuota from the domain object to establish how many computer accounts an ordinary user may create. A computer account is a domain identity, so this value decides whether an ordinary user can mint one.

PRESENT · Ordinary users may create computer accounts, giving any authenticated user a domain identity of their own making: the starting point for several delegation and relay techniques.

SECURITY ASSESSMENT REPORT → Machine Account Quota Allows Domain Join

DORA Art. 9.2 **NIS2** 21.2.i

The domain controller is vulnerable to a known privilege-escalation flaw

noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

NEEDS ATTENTION

2026-08-03

Checked: Asked the domain controller for a Kerberos ticket twice for the same account, once with the privilege attribute certificate requested and once without, and compared the two. A patched controller returns tickets of the same shape; the unpatched defect shows as a materially smaller ticket without the certificate.

PRESENT · The domain controller's ticket-granting behaviour matches the unpatched defect, which takes an ordinary domain user to full domain control.

SECURITY ASSESSMENT REPORT → noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

DORA Art. 9.4, Art. 9.2 **NIS2** 21.2.e, 21.2.i

Passwords Predating Current Policy

NEEDS ATTENTION

2026-08-02

Checked: Took the timestamp of the last change to each password policy from its per-attribute replication metadata (which records when the policy attributes themselves were modified, not when the object was last touched) and compared each enabled account's pwdLastSet against the policy that applies to it.

PRESENT · Enabled accounts still hold a password set before the governing policy was last changed. Active Directory does not apply a policy change retroactively, so those credentials were never required to meet the current rules.

SECURITY ASSESSMENT REPORT → Passwords Predating Current Policy

DORA Art. 6, Art. 9.4 **NIS2** 21.2.j, 21.2.i

Print services are vulnerable to a known remote code-execution flaw

NEEDS ATTENTION

2026-08-03

PrintNightmare Vulnerable Hosts Detected

Checked: Bound to the print spooler service on each reachable host and submitted a deliberately empty driver-installation request, reading the return code to distinguish a host that refuses the call outright from one that accepts it and only rejects the malformed contents.

PRESENT · Hosts accepted a remote driver-installation request. The spooler runs with the highest local privilege, so code loaded this way runs as the machine itself.

SECURITY ASSESSMENT REPORT → PrintNightmare Vulnerable Hosts Detected

DORA Art. 9.4, Art. 11, Art. 17, Art. 19 **NIS2** 21.2.e

SMB message signing (relay resistance)

NEEDS ATTENTION

2026-08-02

Checked: Read the SMB signing policy advertised by each reachable host to identify any that would accept a relayed authentication.

PRESENT · One or more hosts do not require SMB message signing and would accept an authentication relayed from elsewhere in the domain.

SECURITY ASSESSMENT REPORT → SMB Signing Not Required

DORA Art. 9.4(b) **NIS2** 21.2.h, 21.2.e

Weak Default Domain Password Policy

NEEDS ATTENTION

2026-08-02

Checked: Read the Default Domain Password Policy from the domain object and measured three values against the CIS benchmark and the Microsoft security baseline: the account lockout threshold, the minimum password length, and whether the complexity requirement is in force.

PRESENT · One or more of the lockout, length and complexity settings sit below the published baseline, lowering the cost of guessing attacks against every account the policy governs.

SECURITY ASSESSMENT REPORT → Weak Default Domain Password Policy

DORA Art. 6, Art. 9.4 **NIS2** 21.2.j, 21.2.i

SCOPE OF THIS ATTESTATION

This report attests to the controls ADscan actively assessed in this engagement. A control that does not appear above was not assessed, which is not the same as clear: only the entries listed were exercised, and only those marked verified clear carry positive assurance. Coverage is bounded by the scope, the credentials, and the network reachability of this assessment.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.